

SecureForge Web

Relatório de Postura de Segurança

Gerado em 24/07/2026, 16:48:57

Identificação da aplicação

Mattermost

URL: <https://community.mattermost.com/landing#/>
Stack: TypeScript + JavaScript + Go + HTML + SCSS
Análise: Análise 24/07/2026 — Checklist Essential SecureForge v1.0
Concluída em: 24/07/2026
Gerado por: SecureForge Web (secureforgeweb@gmail.com)

Resumo executivo

58%	10	10	0%
Score de postura	Total de achados	Achados abertos	Taxa de resolução

Achados por severidade

Crítica: 3
Alta: 5
Média: 1
Baixa: 1

Plano de ação priorizado

AUTH-02 — Hash de senha forte Crítica · Imediata · Aberto · Autenticação Ação recomendada: Adote bcrypt (custo 12+) ou Argon2id para hash de senhas.
AUTHZ-03 — Rotas administrativas protegidas Crítica · Imediata · Aberto · Autorização Ação recomendada: Exija autenticação + autorização admin em todas as rotas /admin.
INPUT-02 — Queries SQL parametrizadas Crítica · Imediata · Aberto · Validação de entrada Ação recomendada: Use ORM ou prepared statements; nunca concatene SQL com input do usuário.
AUTH-01 — Política de senha mínima Alta · Curto prazo · Aberto · Autenticação Ação recomendada: Exigir 8+ caracteres com maiúscula, minúscula, número e especial.
AUTHZ-02 — Princípio do menor privilégio Alta · Curto prazo · Aberto · Autorização Ação recomendada: Audite papéis e remova acessos desnecessários.

INPUT-01 — Validação server-side

Alta · Curto prazo · Aberto · Validação de entrada

Ação recomendada: Implemente validação com schema (Joi/Zod) em todos os endpoints.

INPUT-03 — Sanitização anti-XSS

Alta · Curto prazo · Aberto · Validação de entrada

Ação recomendada: Escape output, use CSP e frameworks que sanitizam por padrão.

EXPOS-01 — APIs sensíveis autenticadas

Alta · Curto prazo · Aberto · Exposição de endpoints

Ação recomendada: Revise rotas e exija token/sessão em endpoints sensíveis.

EXPOS-02 — Documentação de API restrita

Média · Médio prazo · Aberto · Exposição de endpoints

Ação recomendada: Proteja ou desabilite docs de API em ambiente de produção.

ERROR-02 — Mensagens genéricas ao usuário

Baixa · Baixa · Aberto · Mensagens de erro

Ação recomendada: Use mensagens uniformes para falhas de autenticação e validação.
